

Mapeo Detallado: Preguntas GQM → Requisitos Normativos FAICP

Trazabilidad completa desde cada pregunta de medición hasta el marco regulatorio aplicable

Versión: 1.0 — Abril 2026

Ámbito: España — Regulación aplicable a organizaciones públicas y privadas

Clave de sanciones: (A) Hasta 30M€ o 6% vol. global · (B) Hasta 10M€ o 2% facturación · (C) Hasta 20M€ (RGPD) · (D) Responsabilidad disciplinaria (ENS) · (E) Variable según sector (DORA, NERC-CIP)

Instrucciones de Lectura

Cada fila mapea una **Pregunta GQM** (de la sección 3 del Marco GQM + PRAGMATIC) a los **artículos, controles y requisitos normativos** de los principales marcos regulatorios aplicables en España. Se indica el tipo de obligación (Legal, Técnica, Organizativa), el perfil de organización afectada y el régimen sancionador.

Perfiles de organización:

- **OE/OI:** Operadores Esenciales e Importantes (NIS2)
- **AAPP:** Administraciones Públicas (ENS obligatorio)
- **ProvIA:** Proveedores de sistemas IA (EU AI Act, desarrollo)
- **DesplIA:** Desplegadores de sistemas IA (EU AI Act, uso)
- **EntFin:** Entidades financieras (DORA adicional)
- **TODOS:** Aplicable a cualquier organización que procese datos o use IA

SECCIÓN 1 — FUNCIÓN GOBERNAR: Preguntas Q-GV

Q-GV-01: ¿Existe una política formal de ciberseguridad para IA, aprobada por dirección y revisada en los últimos 12 meses?

Nº	Marco Regulatorio	Artículo / Control	Requisito	Tipo	Perfil	Sanción
1	NIST IR 8596	GV.OC-04 (Tier 1)	Las políticas de ciberseguridad cubren explícitamente los sistemas de IA	Técnica	TODOS	N/A
2	EU AI Act	Art. 9.2	Sistema de gestión de riesgos documentado para sistemas de IA de alto riesgo	Legal	ProvIA, DesplIA	(A)
3	EU AI Act	Art. 9.7	El sistema de gestión de riesgos se revisa y actualiza regularmente	Legal	ProvIA	(A)
4	NIS2	Art. 21.1	Políticas de seguridad de las redes y sistemas de información	Legal	OE/OI	(B)
5	ENS RD 311/2022	Política de seguridad (Marco Org. MP.org.1)	Política de seguridad aprobada por el máximo órgano directivo	Legal	AAPP	(D)

6	ISO/IEC 42001:2023	Cláusula 5.2	Política del sistema de gestión de IA aprobada por la alta dirección	Organizativa	TODOS (voluntario)	N/A
7	ISO/IEC 27001:2022	Cláusula 5.2 + A.5.1	Política de seguridad de la información revisada periódicamente	Organizativa	TODOS (voluntario)	N/A

Análisis de brechas: La principal brecha en España es la ausencia de políticas de ciberseguridad que traten los sistemas de IA de forma específica (no solo mencionada). El 87% de organizaciones españolas carece de políticas actualizadas para IA (Cisco CRI 2025).

Q-GV-02: ¿Están mapeadas todas las dependencias de infraestructura crítica introducidas por sistemas de IA?

Nº	Marco Regulatorio	Artículo / Control	Requisito	Tipo	Perfil	Sanción
1	NIST IR 8596	GV.OC-05 (Tier 1)	Las dependencias de infraestructura crítica con componentes IA están identificadas	Técnica	TODOS	N/A
2	NIS2	Art. 21.2.a	Análisis de riesgos y políticas de seguridad de los sistemas de información	Legal	OE/OI	(B)
3	NIS2	Art. 21.2.d	Seguridad de la cadena de suministro, incluidas las dependencias con terceros proveedores	Legal	OE/OI	(B)
4	EU AI Act	Art. 53.1.c	Los proveedores de modelos de IA de propósito general documentan las dependencias técnicas	Legal	ProvIA	(A)
5	ENS RD 311/2022	ID.AM (Gestión de activos)	Inventario y mapa de dependencias de activos de información	Legal	AAPP	(D)

6	NIST AI RMF	MAP 1.1	Contexto del sistema de IA incluyendo dependenci as y entidades del ecosistema	Técnica	TODOS	N/A
7	DORA	Art. 8.4	Identificaci ón de dependenci as de TIC que puedan representar un único punto de fallo	Legal	EntFin	(E)

Q-GV-03: ¿Incluye el programa de formación en ciberseguridad módulos específicos sobre IA adversarial?

Nº	Marco Regulatorio	Artículo / Control	Requisito	Tipo	Perfil	Sanción
1	NIST IR 8596	GV.RR-04	Los riesgos de IA adversarial se integran en los programas de formación de RRHH	Técnica	TODOS	N/A
2	EU AI Act	Art. 4	Obligación de garantizar alfabetización en IA al personal que trabaja con sistemas IA	Legal	DesplIA, ProvIA	(A)
3	EU AI Act	Art. 26.6	Los desplegados forman a los operadores humanos en los sistemas de IA de alto riesgo	Legal	DesplIA	(A)
4	NIS2	Art. 21.2.g	Formación en ciberseguridad para los empleados	Legal	OE/OI	(B)
5	ENS RD 311/2022	MP.per.3 (Concienciación)	Programa de concienciación en seguridad para el personal	Legal	AAPP	(D)

6	ISO/IEC 42001:2023	Cláusula 7.3	Concienciación sobre el sistema de gestión de IA	Organizativa	TODOS (voluntario)	N/A
7	NIST AI RMF	GOVERN 6.1	Políticas y procedimientos de formación del personal en materia de IA	Técnica	TODOS	N/A

Q-GV-04: ¿Existe un proceso formal y documentado de evaluación de riesgos de proveedores de IA?

Nº	Marco Regulatorio	Artículo / Control	Requisito	Tipo	Perfil	Sanción
1	NIST IR 8596	GV.SC-07 (Tier 1)	Los riesgos de ciberseguridad de los proveedores de IA se evalúan formalmente	Técnica	TODOS	N/A
2	NIS2	Art. 21.2.d	Seguridad de la cadena de suministro y gestión de proveedores	Legal	OE/OI	(B)
3	EU AI Act	Art. 25	Los desplegados verifican las obligaciones de cumplimiento de los proveedores	Legal	DesplIA	(A)
4	EU AI Act	Art. 53.1	Los proveedores de modelos GPAI realizan evaluaciones de proveedores de datos de entrenamiento	Legal	ProvIA	(A)
5	ISO/IEC 42001:2023	B.6.1.3 (Proveedores)	Evaluación de riesgos de los proveedores de componentes IA	Organizativa	TODOS (voluntario)	N/A

6	DORA	Art. 28	Gestión del riesgo de proveedores externos de TIC (incluidos proveedores IA críticos)	Legal	EntFin	(E)
7	ENS RD 311/2022	OP.ext.1 (Cont. externos)	Evaluación de proveedores y contratistas externos con acceso a sistemas	Legal	AAPP	(D)

Q-GV-05: ¿Hay una función de gobernanza de IA con mandato explícito y presupuesto asignado?

Nº	Marco Regulatorio	Artículo / Control	Requisito	Tipo	Perfil	Sanción
1	NIST AI RMF	GOVERN 1.1	Responsabilidades de gobernanza de IA claramente definidas y asignadas	Técnica	TODOS	N/A
2	EU AI Act	Art. 9.1	El proveedor establece un sistema de gestión de riesgos con responsabilidades definidas	Legal	ProvIA	(A)
3	EU AI Act	Art. 27	Los desplegados designan un responsable para sistemas de IA de alto riesgo	Legal	DesplIA	(A)
4	ISO/IEC 42001:2023	Cláusula 5.3	Roles, responsabilidades y autoridades en el sistema de gestión de IA	Organizativa	TODOS (voluntario)	N/A
5	NIS2	Art. 20	El órgano de dirección aprueba, supervisa y responde de las medidas de ciberseguridad	Legal	OE/OI	(B)

6	COBIT 2019	AP012 (Gestión de Riesgos)	Función de gestión del riesgo con responsabili- dades claras	Marco	TODOS	N/A
---	------------	----------------------------------	--	-------	-------	-----

Q-GV-06: ¿Están todos los sistemas de IA clasificados conforme al EU AI Act (Anexo III) y registrados en EUDB?

Nº	Marco Regulatorio	Artículo / Control	Requisito	Tipo	Perfil	Sanción
1	EU AI Act	Art. 49	Registro obligatorio en la base de datos de la UE (EUDB) de sistemas de IA de alto riesgo	Legal	ProvIA, DesplIA (AAPP)	(A)
2	EU AI Act	Art. 6 + Anexo III	Criterios de clasificación de sistemas de IA de alto riesgo	Legal	ProvIA	(A)
3	EU AI Act	Art. 7	Sistemas de IA de alto riesgo según Anexo I (productos de seguridad)	Legal	ProvIA	(A)
4	EU AI Act	Art. 52	Obligaciones de transparencia para sistemas IA con interacción con personas	Legal	ProvIA, DesplIA	(A) reducida
5	AESIA	Guías Prácticas (dic. 2025)	16 guías de cumplimiento EU AI Act publicadas por AESIA	Orientativa	TODOS en ES	N/A
6	ENS RD 311/2022	Marco de gestión de activos	Los sistemas de IA en AAPP clasificados como activos críticos	Legal	AAPP	(D)

SECCIÓN 2 — FUNCIÓN IDENTIFICAR: Preguntas Q-ID

Q-ID-01: ¿Existe un AI-BOM completo para todos los sistemas de IA en producción?

Nº	Marco Regulatorio	Artículo / Control	Requisito	Tipo	Perfil	Sanción
1	NIST IR 8596	ID.AM-07 (Tier 1)	Inventario de sistemas de IA con datos de entrenamiento, arquitectura y dependencias	Técnica	TODOS	N/A
2	EU AI Act	Art. 11	Documentación técnica completa del sistema de IA de alto riesgo antes de comercialización	Legal	ProvIA	(A)
3	EU AI Act	Art. 12	Registro de eventos (logging) de sistemas de IA de alto riesgo	Legal	ProvIA, DesplIA	(A)
4	EU AI Act	Art. 53.2	Los proveedores de GPAI mantienen documentación de modelos incluyendo datos de entrenamiento	Legal	ProvIA GPAI	(A)
5	ISO/IEC 5962:2021	SPDX 2.3	Estándar para Software Bill of Materials extensible a AI-BOM	Técnica	TODOS (voluntario)	N/A

6	NIST SSDF	PS.2.1	Documentación de todos los componentes de software (incluidos modelos) de terceros	Técnica	TODOS	N/A
7	NIS2	Art. 21.2.a	Los activos, incluyendo sistemas de IA, forman parte del análisis de riesgos	Legal	OE/OI	(B)

Q-ID-02: ¿Se realizan evaluaciones de vulnerabilidades específicas para IA que cubran las 10 categorías del OWASP LLM Top 10?

Nº	Marco Regulatorio	Artículo / Control	Requisito	Tipo	Perfil	Sanción
1	OWASP LLM Top 10 2025	LLM01-LLM10	Marco de 10 categorías de vulnerabilidad específicas para LLMs	Técnica	TODOS	N/A
2	EU AI Act	Art. 9.4.b	Pruebas del sistema de IA para identificar medidas de gestión de riesgos apropiadas	Legal	ProvIA	(A)
3	EU AI Act	Art. 9.8	El sistema de IA se somete a pruebas específicas de adversarial robustness	Legal	ProvIA	(A)
4	NIS2	Art. 21.2.e	Adquisición, desarrollo y mantenimiento seguros de sistemas TIC, incluyendo pruebas de vulnerabilidades	Legal	OE/OI	(B)
5	NIST AI RMF	MEASURE 2.5	Se evalúan los riesgos de los sistemas de IA frente a ataques adversariales	Técnica	TODOS	N/A

6	ISO/IEC 42001:2023	B.7.4	Evaluación de amenazas adversarias para sistemas de IA	Organizativa	TODOS (voluntario)	N/A
7	ENS RD 311/2022	RAR.3 / OP.pl.3	Análisis de riesgos que incluya vulnerabilidades de los sistemas de información	Legal	AAPP	(D)

Q-ID-03: ¿Consume la organización inteligencia de amenazas adversariales IA (MITRE ATLAS, feeds CTI IA)?

Nº	Marco Regulatorio	Artículo / Control	Requisito	Tipo	Perfil	Sanción
1	MITRE ATLAS v5.5	Todas las tácticas	Marco de conocimiento de amenazas adversarias IA (66 técnicas, 46 sub-técnicas)	Técnica	TODOS	N/A
2	NIS2	Art. 21.2.h	Uso de inteligencia sobre amenazas cibernéticas y su intercambio	Legal	OE/OI	(B)
3	EU AI Act	Art. 72.2	Las autoridades de supervisión de mercado comparten información sobre vulnerabilidades graves	Legal	AESIA (regulador)	N/A
4	NIST IR 8596	ID.RA-02	Inteligencia sobre amenazas y vulnerabilidades de fuentes internas y externas	Técnica	TODOS	N/A
5	ENISA ETL 2025	—	El panorama de amenazas IA incluye técnicas de ATLAS documentadas en incidentes reales	Referencia	TODOS	N/A

Q-ID-04: ¿Incorpora el modelo de gestión de riesgos la velocidad de ataque IA?

Nº	Marco Regulatorio	Artículo / Control	Requisito	Tipo	Perfil	Sanción
1	NIST IR 8596	ID.RA-04	El análisis de riesgos considera la velocidad y escala de los ataques potenciados por IA	Técnica	TODOS	N/A
2	NIST AI RMF	MAP 2.2	Los riesgos de los sistemas de IA se priorizan considerando su probabilidad e impacto	Técnica	TODOS	N/A
3	ISO/IEC 42001:2023	Cláusula 6.1	Evaluación y tratamiento de riesgos de IA con metodología formal	Organizativa	TODOS (voluntario)	N/A
4	DORA	Art. 6.8	Las entidades financieras evalúan el riesgo de ataques automatizados de alta velocidad	Legal	EntFin	(E)

Q-ID-05: ¿Existe análisis de riesgos de cadena de suministro IA?

Nº	Marco Regulatorio	Artículo / Control	Requisito	Tipo	Perfil	Sanción
1	NIST IR 8596	ID.SC-02	Los riesgos de la cadena de suministro de IA se identifican, analizan y priorizan	Técnica	TODOS	N/A
2	OWASP LLM Top 10	LLM03 (Supply Chain)	Evaluación de vulnerabilidades de cadena de suministro en sistemas LLM	Técnica	TODOS	N/A
3	EU AI Act	Art. 53.1.c	Los proveedores GPAI documentan las dependencias de la cadena de suministro	Legal	ProvIA GPAI	(A)
4	NIS2	Art. 21.2.d	Gestión de la seguridad en las relaciones con proveedores y la cadena de suministro	Legal	OE/OI	(B)
5	DORA	Art. 28-30	Marco para la gestión del riesgo de proveedores TIC críticos, extensible a IA	Legal	EntFin	(E)

6	ENS RD 311/2022	OP.ext.2 (Adquisicio nes)	Requisitos de seguridad en adquisicion es de software y servicios externos	Legal	AAPP	(D)
---	--------------------	---------------------------------	--	-------	------	-----

SECCIÓN 3 — FUNCIÓN PROTEGER: Preguntas Q-PR

Q-PR-01: ¿Aplica la organización gestión de identidades y accesos específica para sistemas y agentes de IA?

Nº	Marco Regulatorio	Artículo / Control	Requisito	Tipo	Perfil	Sanción
1	NIST IR 8596	PR.AA-01 (Tier 1)	Las identidades de los sistemas de IA se gestionan de forma diferenciada	Técnica	TODOS	N/A
2	NIST CSF 2.0	PR.AA-01, PR.AA-02	Gestión de identidades y autenticación para sistemas automatizados	Técnica	TODOS	N/A
3	NIS2	Art. 21.2.i	Gestión de accesos e identidades, incluyendo sistemas automatizados	Legal	OE/OI	(B)
4	ENS RD 311/2022	OP.acc.1-6 (Control de acceso)	Control de acceso de usuarios y sistemas a recursos de información	Legal	AAPP	(D)
5	ISO/IEC 27001:2022	A.8.2, A.8.3	Gestión de acceso privilegiado y gestión de acceso de usuarios	Organizativa	TODOS (voluntario)	N/A
6	DORA	Art. 9.4.c	Control de acceso para sistemas TIC críticos, extensible a agentes IA	Legal	EntFin	(E)

Q-PR-02: ¿Se implementa el principio de menor privilegio en agentes IA autónomos?

Nº	Marco Regulatorio	Artículo / Control	Requisito	Tipo	Perfil	Sanción
1	NIST IR 8596	PR.AA-05 (Tier 1)	Los sistemas de IA autónomos operan con mínimos privilegios necesarios	Técnica	TODOS	N/A
2	OWASP LLM Top 10	LLM06 (Excessive Agency)	Los agentes IA tienen acceso mínimo a herramientas, permisos y recursos externos	Técnica	TODOS	N/A
3	EU AI Act	Art. 14	Supervisión humana de sistemas de IA de alto riesgo, incluyendo capacidad de intervención	Legal	ProvIA, DesplIA	(A)
4	NIST AI RMF	MANAGE 1.3	Mecanismos para supervisar y controlar el comportamiento de sistemas de IA desplegados	Técnica	TODOS	N/A
5	ISO/IEC 42001:2023	B.7.5 (Control de sistemas IA)	Controles para limitar las acciones de los sistemas de IA autónomos	Organizativa	TODOS (voluntario)	N/A

Q-PR-03: ¿Con qué frecuencia recibe el personal formación sobre amenazas IA?

(Ver también Q-GV-03 — requisitos coincidentes)

Nº	Marco Regulatorio	Artículo / Control	Requisito	Tipo	Perfil	Sanción
1	EU AI Act	Art. 4	Alfabetización en IA: formación continua para todo el personal que opera sistemas IA	Legal	DesplIA, ProvIA	(A)
2	NIST IR 8596	PR.AT-01	El personal recibe formación y concienciación sobre amenazas específicas a IA	Técnica	TODOS	N/A
3	NIS2	Art. 21.2.g	Formación básica en ciberseguridad para todos los empleados	Legal	OE/OI	(B)
4	ENS RD 311/2022	MP.per.3, MP.per.4	Concienciación y formación del personal en seguridad	Legal	AAPP	(D)
5	ISO/IEC 27001:2022	A.6.3	Concienciación, educación y formación en seguridad de la información	Organizativa	TODOS (voluntario)	N/A

Q-PR-04: ¿Existen controles de protección de datos de entrenamiento e inferencia?

Nº	Marco Regulatorio	Artículo / Control	Requisito	Tipo	Perfil	Sanción
1	EU AI Act	Art. 10	Prácticas de gobernanza de datos para datos de entrenamiento, validación y prueba	Legal	ProvIA	(A)
2	OWASP LLM Top 10	LLM02 (Sensitive Info Disclosure)	Controles para prevenir la revelación de datos sensibles en outputs de LLMs	Técnica	TODOS	N/A
3	OWASP LLM Top 10	LLM04 (Data & Model Poisoning)	Controles para prevenir el envenenamiento de datos de entrenamiento	Técnica	TODOS	N/A
4	RGPD	Art. 25 (Privacy by Design)	Protección de datos personales en sistemas de IA desde el diseño	Legal	TODOS	(C)
5	RGPD	Art. 35 (EIPD)	Evaluación de Impacto de Protección de Datos para IA de alto riesgo	Legal	TODOS	(C)

6	EU AI Act	Art. 27 (FRIA)	Evaluación de Impacto en los Derechos Fundament ales para IA de alto riesgo en AAPP	Legal	DesplIA AAPP	(A)
7	ENS RD 311/2022	MP.info.2 (Clasificació n)	Clasificació n de información y protección según sensibilidad	Legal	AAPP	(D)

Q-PR-05: ¿Aplica la organización control de versiones formal y prácticas MLOps seguras?

Nº	Marco Regulatorio	Artículo / Control	Requisito	Tipo	Perfil	Sanción
1	NIST IR 8596	PR.PS-01	Los modelos de IA se gestionan con control de versiones y proceso de cambio formal	Técnica	TODOS	N/A
2	EU AI Act	Art. 9.6	Los cambios sustanciales en sistemas de IA de alto riesgo se someten a re-evaluación	Legal	ProvIA	(A)
3	EU AI Act	Art. 12	Los sistemas de IA de alto riesgo mantienen logs automáticos con identificación de versión	Legal	ProvIA, DesplIA	(A)
4	NIST SSDF	PW.4.1	Uso de sistemas de control de versiones para todos los componentes de software	Técnica	TODOS	N/A
5	ISO/IEC 42001:2023	B.6.2.6 (Gestión de cambios IA)	Gestión formal de cambios en sistemas de IA, incluyendo modelos	Organizativa	TODOS (voluntario)	N/A

Q-PR-06: ¿Están acotadas y documentadas las capacidades de acción de los agentes IA?

Nº	Marco Regulatorio	Artículo / Control	Requisito	Tipo	Perfil	Sanción
1	OWASP LLM Top 10	LLM06 (Excessive Agency)	Los agentes IA tienen herramientas, permisos y accesos explícitamente acotados	Técnica	TODOS	N/A
2	EU AI Act	Art. 14	Los sistemas de IA de alto riesgo permiten supervisión humana efectiva	Legal	ProvIA, DesplIA	(A)
3	EU AI Act	Art. 14.4.e	Capacidad para detener el sistema de IA si produce resultados no deseados	Legal	ProvIA, DesplIA	(A)
4	NIST AI RMF	MANAGE 1.3	Mecanismos de supervisión y control activo de los sistemas de IA en operación	Técnica	TODOS	N/A
5	MITRE ATLAS	AML.T0053 (Tool Invocation)	Técnica documentada de abuso de invocación de herramientas por agentes IA	Referencia	TODOS	N/A

SECCIÓN 4 — FUNCIÓN DETECTAR: Preguntas Q-DE

Q-DE-01: ¿Están monitorizadas las comunicaciones con APIs de IA externas?

Nº	Marco Regulatorio	Artículo / Control	Requisito	Tipo	Perfil	Sanción
1	NIST IR 8596	DE.CM-06 (Tier 1)	Monitorización de comunicaciones de sistemas de IA con servicios externos	Técnica	TODOS	N/A
2	OWASP LLM Top 10	LLM10 (Unbound Consumption)	Monitorización de consumo de APIs para detectar uso anómalo o abusivo	Técnica	TODOS	N/A
3	NIS2	Art. 21.2.b	Gestión de incidentes incluyendo detección de actividad anómala en redes	Legal	OE/OI	(B)
4	ENS RD 311/2022	OP.mon.1 (Intrusiones) + OP.mon.3	Monitorización del sistema y detección de código dañino y actividad anómala	Legal	AAPP	(D)
5	DORA	Art. 10.3	Monitorización continua de las actividades de las TIC, incluyendo APIs externas	Legal	EntFin	(E)

Q-DE-02: ¿Existe monitorización en tiempo de ejecución de sistemas IA en producción?

Nº	Marco Regulatorio	Artículo / Control	Requisito	Tipo	Perfil	Sanción
1	NIST IR 8596	DE.CM-09 (Tier 1)	Monitorización del comportamiento de los sistemas de IA en ejecución	Técnica	TODOS	N/A
2	EU AI Act	Art. 72.1	Los desplegados implementan monitorización post-mercado de sistemas de IA de alto riesgo	Legal	DesplIA	(A)
3	EU AI Act	Art. 12	Registro automático de eventos del sistema de IA en producción	Legal	ProvIA, DesplIA	(A)
4	NIST AI RMF	MEASURE 2.5	Monitorización continua de los sistemas de IA para detectar comportamiento anómalo	Técnica	TODOS	N/A
5	ISO/IEC 42001:2023	B.8.3 (Monitorización IA)	Monitorización del rendimiento y comportamiento de sistemas de IA en operación	Organizativa	TODOS (voluntario)	N/A

Q-DE-03: ¿Con qué frecuencia se evalúa el model drift y data drift?

Nº	Marco Regulatorio	Artículo / Control	Requisito	Tipo	Perfil	Sanción
1	EU AI Act	Art. 72.1	Monitorización post-mercado que incluye evaluación de degradación del rendimiento	Legal	DesplIA	(A)
2	EU AI Act	Art. 9.7	El sistema de gestión de riesgos se revisa a la luz del comportamiento real del sistema IA	Legal	ProvIA	(A)
3	NIST AI RMF	MEASURE 2.6	Evaluación periódica del comportamiento real del sistema de IA vs. comportamiento esperado	Técnica	TODOS	N/A
4	ISO/IEC 42001:2023	B.8.4 (Evaluación continua)	Evaluación continua de la adecuación del sistema de IA a su propósito	Organizativa	TODOS (voluntario)	N/A
5	DORA	Art. 10.4	Capacidad para identificar degradación del rendimiento de sistemas TIC críticos	Legal	EntFin	(E)

Q-DE-04: ¿Están los analistas del SOC capacitados para detectar tácticas MITRE ATLAS?

Nº	Marco Regulatorio	Artículo / Control	Requisito	Tipo	Perfil	Sanción
1	MITRE ATLAS v5.5	Todas las tácticas	Marco de referencia de 15 tácticas y 66 técnicas para ataques adversariales IA	Técnica	TODOS	N/A
2	NIS2	Art. 21.2.g	Formación especializada del personal de seguridad	Legal	OE/OI	(B)
3	NIST IR 8596	DE.CM-09 + ID.RA-02	El equipo de seguridad conoce las técnicas de ataque específicas para sistemas IA	Técnica	TODOS	N/A
4	ENS RD 311/2022	OP.exp.3 (Gestión de Incidentes)	Personal cualificado para detección y respuesta a incidentes de seguridad	Legal	AAPP	(D)

Q-DE-05: ¿Existen controles técnicos de detección de prompt injection?

Nº	Marco Regulatorio	Artículo / Control	Requisito	Tipo	Perfil	Sanción
1	OWASP LLM Top 10	LLM01 (Prompt Injection)	Controles de detección y mitigación de ataques de inyección de prompt	Técnica	TODOS	N/A
2	NIST IR 8596	DE.CM-03	Monitorización de entornos de ejecución de IA para detección de anomalías de entrada	Técnica	TODOS	N/A
3	EU AI Act	Art. 9.4	Medidas técnicas para reducir riesgos específicos identificados en la evaluación de riesgos	Legal	ProvIA	(A)
4	MITRE ATLAS	AML.T0051 (LLM Prompt Injection)	Técnica documentada de inyección de prompt con sub-técnicas directa e indirecta	Referencia	TODOS	N/A

SECCIÓN 5 — FUNCIÓN RESPONDER: Preguntas Q-RS

Q-RS-01: ¿Existen playbooks formales y probados para respuesta a incidentes IA?

Nº	Marco Regulatorio	Artículo / Control	Requisito	Tipo	Perfil	Sanción
1	NIST IR 8596	RS.MA-01 (Tier 1)	Planes de respuesta a incidentes específicos para sistemas de IA	Técnica	TODOS	N/A
2	NIS2	Art. 21.2.b	Gestión de incidentes: planes, procedimientos y procesos de respuesta formales	Legal	OE/OI	(B)
3	ENS RD 311/2022	OP.exp.2 (Planificación)	Planes de respuesta a incidentes documentados y probados	Legal	AAPP	(D)
4	ISO/IEC 27001:2022	A.5.26 (Respuesta a incidentes)	Respuesta a incidentes de seguridad de la información con procedimientos documentados	Organizativa	TODOS (voluntario)	N/A
5	DORA	Art. 18	Procedimientos de gestión de incidentes TIC, incluyendo clasificación y respuesta	Legal	EntFin	(E)

6	EU AI Act	Art. 73.1	Procedimientos para reportar incidentes graves en sistemas de IA de alto riesgo	Legal	ProvIA, DesplIA	(A)
---	-----------	-----------	---	-------	-----------------	-----

Q-RS-02: ¿Dispone la organización de capacidades de análisis forense específico para IA?

Nº	Marco Regulatorio	Artículo / Control	Requisito	Tipo	Perfil	Sanción
1	NIST IR 8596	RS.AN-03	Análisis forense de incidentes en sistemas de IA con trazabilidad de decisiones	Técnica	TODOS	N/A
2	EU AI Act	Art. 12	Los logs de sistemas de IA de alto riesgo permiten la trazabilidad post-incidente	Legal	ProvIA, DesplIA	(A)
3	NIS2	Art. 23.3	El informe final de incidente incluye análisis de causa raíz	Legal	OE/OI	(B)
4	ENS RD 311/2022	OP.exp.3 (Análisis forense)	Capacidades de análisis forense para incidentes de seguridad	Legal	AAPP	(D)

Q-RS-03: ¿Conoce el equipo los plazos de notificación a AESIA y NIS2?

Nº	Marco Regulatorio	Artículo / Control	Plazo	Perfil	Sanción
1	EU AI Act	Art. 73.1	15 días hábiles desde conocimiento del incidente grave en IA de alto riesgo → AESIA	ProvIA, DesplIA	(A)
2	NIS2	Art. 23.1.a	24 horas alerta temprana ante incidente significativo → autoridad nacional	OE/OI	(B)
3	NIS2	Art. 23.1.b	72 horas notificación de incidente significativo con evaluación inicial → INCIBE/CCN	OE/OI	(B)
4	NIS2	Art. 23.4	30 días informe final completo con causa raíz y medidas adoptadas	OE/OI	(B)
5	RGPD	Art. 33	72 horas notificación de brecha de datos personales → AEPD	TODOS	(C)
6	DORA	Art. 19.4	4 horas desde clasificación como mayor: alerta temprana → autoridad competente	EntFin	(E)
7	DORA	Art. 19.4.b	24 horas notificación inicial del incidente mayor	EntFin	(E)

Q-RS-04: ¿Cuál es el MTTR-AI de la organización?

Nº	Marco Regulatorio	Artículo / Control	Requisito	Tipo	Perfil	Sanción
1	NIST IR 8596	RS.AN-03	Medición del tiempo de respuesta a incidentes en sistemas de IA	Técnica	TODOS	N/A
2	NIS2	Art. 21.2.b	Capacidades de respuesta efectiva a incidentes con métricas de rendimiento	Legal	OE/OI	(B)
3	DORA	Art. 18.2.e	Clasificación, diagnóstico y resolución de incidentes TIC con tiempos objetivos	Legal	EntFin	(E)
4	ENS RD 311/2022	OP.exp.3	Gestión de incidentes con seguimiento de métricas de tiempo de respuesta	Legal	AAPP	(D)

SECCIÓN 6 — FUNCIÓN RECUPERAR: Preguntas Q-RC

Q-RC-01: ¿Incluyen los planes de recuperación rollback de modelos de IA?

Nº	Marco Regulatorio	Artículo / Control	Requisito	Tipo	Perfil	Sanción
1	NIST IR 8596	RC.RP-02 (Tier 1)	Los planes de recuperación incluyen procedimientos de rollback de versiones de modelos IA	Técnica	TODOS	N/A
2	NIS2	Art. 21.2.c	Planes de continuidad de las actividades y gestión de crisis, incluyendo copias de seguridad	Legal	OE/OI	(B)
3	EU AI Act	Art. 9.5	Medidas de gestión de riesgos para eliminar o mitigar riesgos residuales, incluyendo rollback	Legal	ProvIA	(A)
4	DORA	Art. 12	Planes de continuidad TIC con capacidades de restauración probadas	Legal	EntFin	(E)
5	ENS RD 311/2022	OP.cont.1 (Plan de continuidad)	Plan de continuidad que incluye la recuperación de sistemas críticos	Legal	AAPP	(D)

Q-RC-02: ¿Cuál es el RTO-AI para los sistemas de IA clasificados como críticos?

Nº	Marco Regulatorio	Artículo / Control	Requisito	Tipo	Perfil	Sanción
1	NIS2	Art. 21.2.c	Los planes de continuidad definen objetivos de tiempo de recuperación	Legal	OE/OI	(B)
2	DORA	Art. 24	Pruebas de recuperación TIC incluyendo RTO verificado en ejercicios reales	Legal	EntFin	(E)
3	ENS RD 311/2022	OP.cont.2 (Pruebas)	Pruebas periódicas del plan de continuidad con métricas de RTO	Legal	AAPP	(D)
4	ISO/IEC 22301:2019	Cláusula 8.4.4	RTPO (Recovery Time/Point Objectives) definidos para procesos críticos	Organizativa	TODOS (voluntario)	N/A
5	NIST IR 8596	RC.RP-02	Los objetivos de recuperación para sistemas de IA están definidos y verificados	Técnica	TODOS	N/A

Q-RC-03: ¿Existe un proceso para revisar decisiones tomadas por el sistema comprometido?

Nº	Marco Regulatorio	Artículo / Control	Requisito	Tipo	Perfil	Sanción
1	EU AI Act	Art. 72.1	Monitorización post-mercado para identificar incidentes y sus consecuencias en los afectados	Legal	DesplIA	(A)
2	NIST IR 8596	RC.RP-03	Revisión post-incidente de los efectos del sistema de IA durante el período comprometido	Técnica	TODOS	N/A
3	EU AI Act	Art. 73.3	Notificación de incidentes graves que incluya análisis del impacto en personas afectadas	Legal	ProvIA, DesplIA	(A)
4	RGPD	Art. 34	Comunicación a los interesados cuando la brecha de datos cause riesgo elevado	Legal	TODOS	(C)

5	EU AI Act	Art. 86	Derecho de los afectados a una explicación de las decisiones tomadas por sistemas de IA	Legal	DesplIA	(A)
6	NIST AI RMF	MANAGE 4.2	Evaluación de las consecuencias de incidentes de IA, incluyendo revisión de decisiones	Técnica	TODOS	N/A

Anexo: Cuadro Sinóptico de Marcos y Ámbito de Aplicación

Marco	Tipo	Emisor	Obligatorio para	Sanciones	Vigencia España
EU AI Act 2024/1689	Reglamento	Comisión Europea	ProvIA, DesplIA (gradual)	Hasta 30M€ o 6% vol. global	Desde ago. 2024; obligaciones escalonadas hasta 2027
NIS2 2022/2555	Directiva	Consejo UE	OE/OI (>50 empleados o >10M€)	Hasta 10M€ o 2% facturación	Transpuesta en España (RDL previsto)
NIST IR 8596	Informe técnico	NIST (EE.UU.)	Voluntario (referencia técnica)	N/A	Borrador dic. 2025; referencia global
NIST AI RMF 1.0	Marco voluntario	NIST (EE.UU.)	Voluntario (muy adoptado)	N/A	Vigente desde ene. 2023
ENS RD 311/2022	Real Decreto	Gobierno España	AAPP y sus proveedores TIC	Responsabilidad disciplinaria	Vigente; revisión periódica CCN
ISO/IEC 42001:2023	Norma	ISO/IEC	Voluntario	N/A	Certificación disponible desde dic. 2023
OWASP LLM Top 10 2025	Guía técnica	OWASP	Voluntario (referencia técnica)	N/A	Versión 2025, nov. 2024
MITRE ATLAS v5.5	Base de conocimiento	MITRE	Voluntario (referencia técnica)	N/A	v5.5 mar. 2026
RGPD 679/2016	Reglamento	Comisión Europea	TODOS (datos personales)	Hasta 20M€ o 4% vol. global	Vigente desde may. 2018
DORA 2022/2554	Reglamento	Comisión Europea	Entidades financieras	Variable	Vigente desde ene. 2025